Software Engineering Lab 5

Bharat Shandilya | PES2UG24CS906

1. Objective

The objective of this lab was to apply static code analysis to a Python insurance premium calculator, identify code-quality problems and potential security weaknesses, correct the issues, and compare the analysis results before and after the changes.

Tools used: Pylint for code quality and potential programming mistakes, Bandit for common security issues, and Flake8 for style and formatting checks.

2. Before-and-after summary

Tool	Before	After / changes
Pylint	Original score: 5.73/10 (baseline report). The code had naming and documentation issues, a mutable default argument, excessive function arguments, file-handling concerns, and other maintainability warnings.	Final screenshot shows 10.00/10. Naming, documentation, formatting, argument handling, and other reported code-quality issues were addressed.
Bandit	Baseline report contained 10 findings: 1 high, 5 medium, and 4 low severity. Findings included unsafe archive extraction, binding to all interfaces, insecure TLS handling, XML parsing concerns, hard-coded token, and use of non-cryptographic randomness.	The final Bandit run reported “No issues identified.” Security-sensitive operations were hardened, including verified TLS, safer XML parsing, safer archive extraction, environment-based token configuration, and cryptographically secure randomness.
Flake8	Baseline report contained 19 style violations, including long lines, spacing/blank-line issues, and bare-except usage.	The saved after-report was empty, consistent with no Flake8 violations being reported in that run.

3. Important issues fixed

Issue / area	What was changed
Mutable default argument	Changed the request representation to use an immutable default for discounts, avoiding shared state between calls.
Input validation and premium calculation	Added validation for request values and ensured the calculated premium cannot become negative.
Unsafe archive extraction	Used tarfile extraction with the data filter to reduce path-traversal and unsafe extraction risks.
TLS and URL handling	Used HTTPS with certificate verification and checked the URL/ port before fetching rates.
XML parsing	Replaced the standard XML parser with defusedxml to mitigate common XML-related attacks.
Hard-coded token and randomness	Read the authorisation token from an environment variable and used secrets for policy-number generation.
File handling	Used context managers and explicit UTF-8 encoding when saving files.
Code quality and readability	Added documentation, snake_case names, clearer structure, and corrected style issues flagged by Pylint/Flake8.
Other behaviour improvements	Handled renewal dates around leap years and simplified iteration and conditional logic.

4. Final analysis results

The final results indicate a substantial improvement in static-analysis findings. Pylint reached 10.00/10 in the supplied final screenshot, and the final Bandit run reported no issues. The after Flake8 report was empty, which is consistent with a clean style check. Static analysis does not prove that a program is free from all defects; functional tests and code review are still important.

5. Evidence screenshots

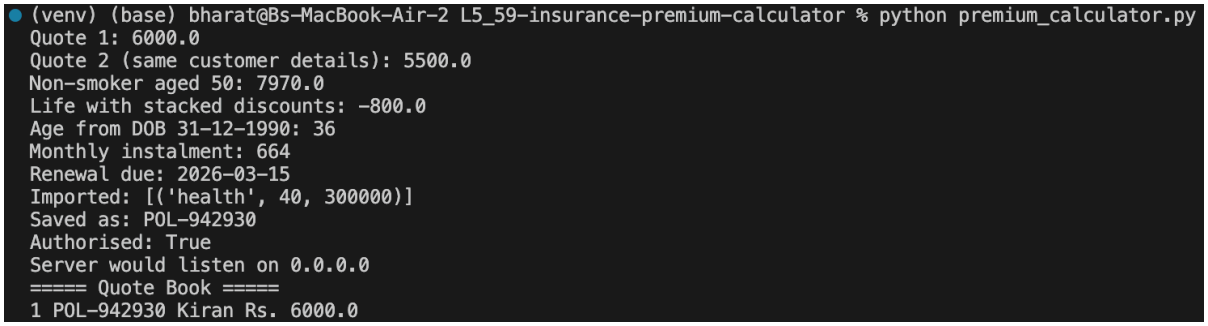


Figure 1. Baseline Pylint output showing the original code-quality issues and score.

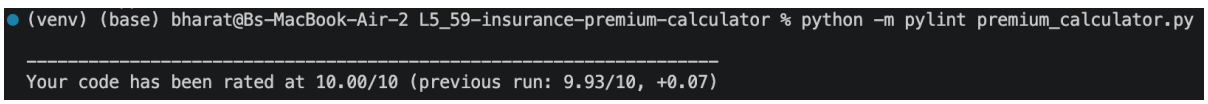


Figure 2. Final Pylint output showing a score of 10.00/10.

```
(venv) (base) bharat@Bs-MacBook-Air-2 L5_59-insurance-premium-calculator % python premium_calculator.py
Quote 1: 6000.0
Quote 2 (same customer details): 5500.0
Non-smoker aged 50: 7970.0
Life with stacked discounts: -800.0
Age from DOB 31-12-1990: 36
Monthly instalment: 664
Renewal due: 2026-03-15
Imported: [('health', 40, 300000)]
Saved as: POL-597855
Authorised: False
Server would listen on 127.0.0.1
===== Quote Book =====
1 POL-597855 Kiran Rs. 6000.0
```

Figure 3. Example execution of the corrected premium calculator.

```
(venv) (base) bharat@Bs-MacBook-Air-2 L5_59-insurance-premium-calculator % python premium_calculator.py
Quote 1: 6000.0
Quote 2 (same customer details): 6000.0
Non-smoker aged 50: 6900.0
Life with stacked discounts: 0.0
Age from DOB 31-12-1990: 35
Monthly instalment: 575
Renewal due: 2026-03-15
Imported: [('health', 40, 300000)]
Saved as: POL-328596
Authorised: False
Server would listen on 127.0.0.1
===== Quote Book =====
1 POL-328596 Kiran Rs. 6000.0
(venv) (base) bharat@Bs-MacBook-Air-2 L5_59-insurance-premium-calculator % python -m pylint premium_calculator.py
************* Module premium_calculator
premium_calculator.py:1:0: C0114: Missing module docstring (missing-module-docstring)

-------------------------------------------------------------------
Your code has been rated at 9.93/10 (previous run: 7.35/10, +2.58)
```

Figure 4. Additional execution output showing the authorisation result and server binding configuration.

```
(venv) (base) bharat@Bs-MacBook-Air-2 L5_59-insurance-premium-calculator % python -m pylint premium_calculator.py
************* Module premium_calculator
premium_calculator.py:154:0: C0301: Line too long (148/100) (line-too-long)
premium_calculator.py:1:0: C0114: Missing module docstring (missing-module-docstring)
premium_calculator.py:21:0: C0116: Missing function or method docstring (missing-function-docstring)
premium_calculator.py:21:0: C0103: Function name "calculatePremium" doesn't conform to snake_case naming style (invalid-name)
premium_calculator.py:21:0: W0102: Dangerous default value [] as argument (dangerous-default-value)
premium_calculator.py:21:0: R0913: Too many arguments (6/5) (too-many-arguments)
premium_calculator.py:21:0: R0917: Too many positional arguments (6/5) (too-many-positional-arguments)
premium_calculator.py:34:0: C0116: Missing function or method docstring (missing-function-docstring)
premium_calculator.py:34:0: C0103: Function name "ageFromDob" doesn't conform to snake_case naming style (invalid-name)
premium_calculator.py:40:0: C0103: Function name "policyNumber" doesn't conform to snake_case naming style (invalid-name)
premium_calculator.py:44:0: C0116: Missing function or method docstring (missing-function-docstring)
premium_calculator.py:44:0: C0103: Function name "saveQuote" doesn't conform to snake_case naming style (invalid-name)
premium_calculator.py:47:8: W1514: Using open without explicitly specifying an encoding (unspecified-encoding)
premium_calculator.py:48:12: C0209: Formatting a regular string which could be an f-string (consider-using-f-string)
premium_calculator.py:47:8: R1732: Consider using 'with' for resource-allocating operations (consider-using-with)
premium_calculator.py:52:0: C0103: Function name "importPolicies" doesn't conform to snake_case naming style (invalid-name)
premium_calculator.py:76:0: C0103: Function name "fetchRates" doesn't conform to snake_case naming style (invalid-name)
premium_calculator.py:112:0: C0103: Function name "importClaimDocuments" doesn't conform to snake_case naming style (invalid-name)
premium_calculator.py:120:0: C0116: Missing function or method docstring (missing-function-docstring)
premium_calculator.py:120:0: C0103: Function name "monthlyInstalment" doesn't conform to snake_case naming style (invalid-name)
premium_calculator.py:121:4: R1705: Unnecessary "else" after "return", remove the "else" and de-indent the code inside it (no-else-return)
premium_calculator.py:126:0: C0116: Missing function or method docstring (missing-function-docstring)
premium_calculator.py:126:0: C0103: Function name "isAuthorised" doesn't conform to snake_case naming style (invalid-name)
premium_calculator.py:127:4: R1703: The if statement can be replaced with 'return bool(test)' (simplifiable-if-statement)
premium_calculator.py:127:4: R1705: Unnecessary "else" after "return", remove the "else" and de-indent the code inside it (no-else-return)
premium_calculator.py:132:0: C0116: Missing function or method docstring (missing-function-docstring)
premium_calculator.py:132:0: C0103: Function name "renewalDue" doesn't conform to snake_case naming style (invalid-name)
premium_calculator.py:136:0: C0116: Missing function or method docstring (missing-function-docstring)
premium_calculator.py:136:0: C0103: Function name "printQuotes" doesn't conform to snake_case naming style (invalid-name)
premium_calculator.py:139:4: C0200: Consider using enumerate instead of iterating with range and len (consider-using-enumerate)
premium_calculator.py:142:0: C0116: Missing function or method docstring (missing-function-docstring)

-------------------------------------------------------------------
Your code has been rated at 7.35/10 (previous run: 5.73/10, +1.62)
```

Figure 5. Initial pylint output

6. Conclusion

The lab demonstrated how combining Pylint, Bandit, and Flake8 gives broader coverage than using one tool alone. The code was improved for readability, maintainability, input handling, and security. Before-and-after reports were saved in the project's reports/before and reports/after folders, and the issue table and reflection were documented separately in issues.md and reflection.md.

Thank you :)